La sauvegarde du coffre sera ainsi générée au format .cred On peu ensuite l'exfiltrer vers notre windows retaper la commande ouvrant le Credential manager cliquer sur restorer et choisir notre "archive" .cred puis sur mimikatz* pour extraire les credentials ainsi "injecté en mémoire". Pour énumérer les identifiants stockés dans le profil de l'utilisateur actuel on à la commande cmdkey /list

* privilège: debug et sekurlsa : vadmin

Attaquer Active Directory et NTDS.dit:

Active Directory est un service d'annuaire courant et essentiel dans les réseaux d'entreprise moderne. L'attaque AD est si vaste que nous l'aborderons seulement dans la CPTS, mon chemin sera CPTS -> Maitrise d'un langage de programmation offensif -> CAPE -> CWEE. Ici nous nous concentrerons sur l'attaque et l'extraction des hashages du fichier NTDS.dit.

A partir du moment ou notre system est joint à un domaine on peu oublier la base de donnée SAM pour l'authentification, tout se passe au controller de domain

NT Directory Service (NTDS) est le service d'annuaire utilisé avec AD pour trouver et organiser les ressources réseaux. Le fichier NTDS.dit est stocker dans %SystemRoot% ntds sur les controllers de domain d'une forêt.

Pour faire une copie de NTDS.dit (et ensuite l'exfiltrer) on a besoin de droits d'administrateur local ou d'administrateur de domain pour vérifier les privilèges du compte on peu utiliser :

```
PS C:\> net user username
```

[+] avec vssadmin on créé une copie du volume C: ou se trouve le ntds.dit

```
PS C:\> vssadmin CREATE SHADOW /For=C:
```

[+] on va ensuite copier le fichier NTDS.dit du cliché instantané du volume C: vers un autre emplacement - (pour faciliter l'exfiltration)

```
PS C:\NTDS> cmd.exe /c copy \\?\GLOBALROOT\Device\HarddiskVolumeShadowCopy2\Windows\NTDS\NTDS.dit C:\Users\lol\Desktop\lol.dit
```

\System32\config\SYSTEM

[+] On peux aussi directement capturer le fichier avec netexec

```
Agentpathogene@Desktop ~$ nxcc smb ip -u username -p p@ssword! -M ntdsutil
```

L'extraction des hashages peux être effectuée sur notre copie exfiltrer avec impacket-secretsdump et le cassage de ceux ci avec hashcat.

```
Agentpathogene@parrot ~$ impacket-secretsdump -ntds NTDS.dit -system SYSTEM LOCAL
```

● n'oublions pas d'exfiltrer aussi d'exfiltrer le fichier SYSTEM contenant la clé necessaire au déchiffrement le chemin est spécifié en vert au dessus

▲ Avec des noms d'utilisateurs appartenant probablement au domain on peu utiliser le script username-anarchy pour generer des "nom" wordlist avec les combinaisons courantes en entreprise ▲ rappelons que le bruteforce n'est jamais discret et peu amener a un blocage simple de toute notre "avancée".

Et pour cloturer notre chasse aux identifiants windows 1- n'oublions pas de chercher dans des fichiers ou un utilisateur ou administrateur les aurait entreposé en texte clair 2- Le navigateur ou d'autres applications qui peuvent stocker des crédential de manière non sécurisée pour cela notre couteau suisse est LaZagne.exe qui intègre des modules pour les browsers, applications de messageries, boites mail, fichier de ~~passwd~~ config, mémoire et j'en passe. Pour le lancer sur la cible avec tout les modules : C:\Users\target\Desktop> start Lazagne.exe all

Sauvegarde fichier

on à aussi un petit -vv pour suivre les actions en mode cerbeux. et -oN ✓